

ClaimsFlow Gap Analysis & Implementation Plan

A comprehensive business analysis of the current system state, identified gaps, and a phased roadmap for closing those gaps to reach full SRD compliance.

Date	Version	Reference	Classification
12 May 2026	1.0 — Initial Release	CIC- RFQ-65-25	Internal — Restricted

SECTION 1

Executive Summary

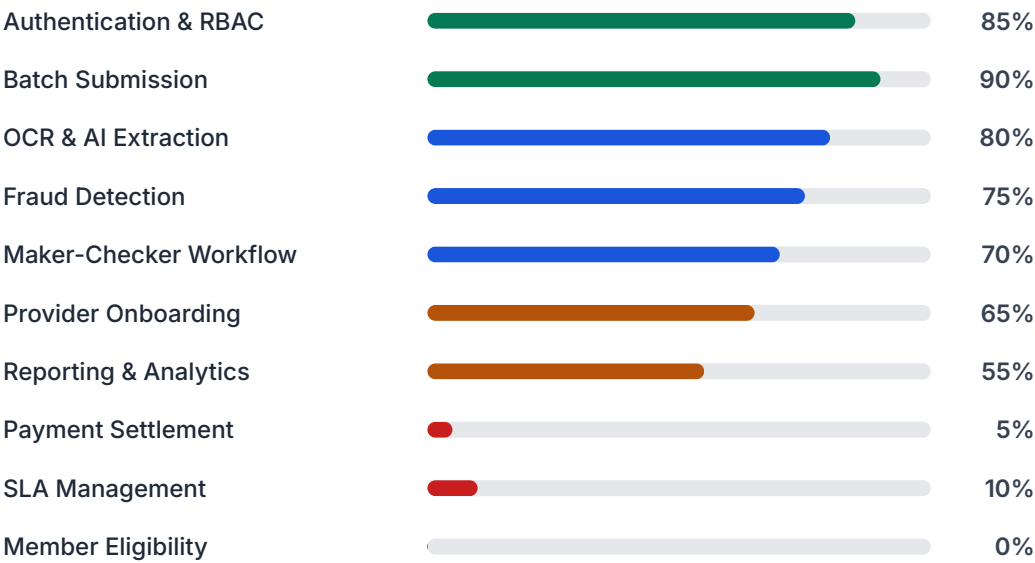
ClaimsFlow is CIC Insurance Group's medical claims automation platform. This document assesses what has been delivered, what functional gaps remain, and prescribes a prioritised four-phase implementation roadmap to close those gaps — enabling full automation, compliance, and operational efficiency across the claims lifecycle.



Business Context

CIC processes hundreds of medical claims per day across a network of hospitals, clinics, dental centres, and pharmacies. The platform automates intake, OCR extraction, fraud detection, and multi-level approval. However, the absence of a payment settlement module, SLA enforcement, member eligibility verification, and a formal appeals workflow creates operational risk that this plan directly addresses.

Current System Strengths



SECTION 2

Current System State

A module-by-module inventory of what is live and operational in ClaimsFlow today, with completion status and notable caveats.

Module	Status	What Is Built	Caveats
Authentication	Live	JWT tokens, bcrypt passwords, account lockout after 5 failures, forced password change on first login, session persistence across cold starts, role-aware redirect on login.	2FA code exists but is disabled (controller renamed to .disabled)
RBAC	Live	Seven roles: Admin, Supervisor, Claims Officer (Maker), Checker, Fraud Officer, Provider Admin, Provider User. Granular permissions table with role-permission mapping. Branch-scoped provider access.	UI for assigning custom permissions still limited
Provider Management	Partial	Self-service registration with onboarding documents (incorporation cert, KRA PIN, reference letters). Admin approval workflow. Branch management with region/county. Provider status lifecycle (pending → active).	No provider performance scorecard; purge workflow limited
Batch Submission	Live	Drag-and-drop multi-file upload. Unique batch numbers. PDF watermarking with batch number. Barcode (Code128) stamped per claim. TIFF-to-PDF conversion. Resumable uploads. Queue-based async processing.	No scan station hardware integration
Email Ingestion	Live	Gmail and Outlook OAuth 2.0 polling (every 5 min). Extracts PDF attachments, creates batch submissions	Requires OAuth refresh

Module	Status	What Is Built	Caveats
		automatically. Configurable subject filter. Manual poll trigger in Settings.	token setup per mailbox
OCR Engine	Live	Multi-AI vision routing: Claude Opus, Gemini 1.5 Pro, Ollama (local), Tesseract fallback. Circuit breaker per provider (5-min cooldown on quota errors). Per-field confidence scoring. Template + zone system for known providers.	Ollama requires local GPU; accuracy varies by document quality
Document Classifier	Live	Gemini-powered document type classification. Zone-based OCR templates with drag-and-drop field placement editor. Unknown document queue with human review and claim linking.	Template training requires sample documents per provider
Fraud Detection	Live	10 automated fraud signals: round-amount billing, duplicate invoice, missing member identity, high-value threshold, future dates, impossible date sequences, stale claims (>90 days), same-batch member velocity, provider mismatch, low OCR confidence.	ML-based anomaly scoring not yet implemented
Maker-Checker Workflow	Live	Four-stage pipeline: Initial Review → Maker Review → Checker Review → Final Approval. Role-enforced stage access. Separate queues per role. Claim assignment strategies. Rejection with specific reasons and provider notification.	No SLA timer; no auto-escalation on breach
Document Management	Live	PDF viewer with annotation canvas (highlight, stamp, signature). Document versioning. Merge, split, rotate, reorder pages. Purge request workflow. EDMS integration (graceful degradation when not configured).	Purge approval UI limited; EDMS sync may lag

Notifications

Module	Status	What Is Built	Caveats
	Live	Email (SMTP via Nodemailer) and SMS (Africa's Talking / Twilio) for all key events: batch received, claim approved/rejected, maker/checker assignment, provider status change.	No real-time WebSocket push; browser notifications absent
Reports & Analytics	Partial	Claims volume by period, approvals/rejections, fraud signals report, provider performance, processing time, upload summary. Excel/CSV/JSON export. Dashboard charts (area, bar, pie, composed).	Reports pull from client-side store, not live API. Scheduled reports not wired. No drill-down.
Audit Logs	Live	Comprehensive activity logging: all API actions, user/role/IP captured, old/new values for changes, filterable UI with CSV export.	Log retention policy not configurable from UI
eOxygen / EDMS Integration	Partial	Local data saved for both EDMS and eOxygen. Outbound sync wired but in graceful-degradation mode — only activates when API keys are set.	Live credentials not yet provided; sync untested in production
Payment Settlement	Not Built	Claim status field includes paid but no payment module exists. Finance receives no structured handoff from the system.	Critical gap — claims loop completes on paper, not in system
Member Eligibility	Not Built	Member number and name are captured but never validated against the policy/member database.	Ghost claims can pass without this check
Two-Factor Auth	Not Built	TOTP service (speakeasy + QRCode) is written and wired to notifications, but the HTTP controller is disabled. Frontend setup page exists but never succeeds.	Security gap for privileged accounts

SECTION 3

Identified Gaps

All functional, technical, and compliance gaps ranked by impact severity. Each gap includes its business impact and the affected stakeholder groups.

Critical Gaps (P1) — Operational Blockers

These gaps prevent the system from completing the full claims lifecycle or expose the business to financial and compliance risk.

#	Gap	Business Impact	Affected Roles	Priority
G01	No Payment Settlement Module Approved claims have no structured handoff to Finance. Payment status tracked only as a manual field update with no EFT, bank integration, or payment advice generation.	Finance team cannot reconcile claims. Providers have no payment visibility. SLA on settlement (72hr target) cannot be measured or enforced.	Finance, Supervisor, Provider	Critical
G02	Two-Factor Authentication Disabled The TOTP service is code-complete but the NestJS controller file was renamed to .disabled, making all 2FA endpoints unreachable.	Admin, supervisor, checker, and fraud officer accounts are protected only by password — a single-factor risk. Regulatory frameworks (ISO 27001, CBK guidelines) may require MFA for privileged roles.	All privileged users	Critical
G03	Password Reset Flow Incomplete The Forgot Password frontend page exists, but the	Users who forget passwords must contact an admin to reset manually. This is a friction	All users	Critical

#	Gap	Business Impact	Affected Roles	Priority
	backend has no POST /auth/forgot-password or POST /auth/reset-password endpoints. Password reset tokens are never generated or emailed.	point for provider onboarding and creates an admin bottleneck.		
G04	No Member Eligibility Verification Member numbers and names are captured via OCR but never validated against CIC's member/policy database (Smart or eOxegen). No eligibility API call at claim submission.	Ghost claims (non-member or expired-policy claims) pass fraud detection and enter the workflow. First-line fraud prevention is bypassed, increasing payout risk.	Claims Officer, Fraud Officer, Supervisor	Critical
G05	No SLA Enforcement or Escalation Claims sit in queues indefinitely with no timer, no breach alert, and no auto-escalation. Processing-time data exists in the report module but nothing triggers action on breaches.	Provider SLA agreements (e.g. 48-hour turnaround) are unenforceable in the system. Supervisors have no visibility into aging claims until they manually search.	Supervisor, Claims Officer, Provider	Critical
G06	Reports Not API-Driven (Client-Side Only) All report charts and tables on the Reports page are built from the in-memory Zustand store (claims loaded in the browser) rather than calling the server-side	Reports are silently incomplete when the browser store hasn't loaded all records. Large datasets (10,000+ claims) will show wrong figures. Management	Supervisor, Finance, Management	Critical

#	Gap	Business Impact	Affected Roles	Priority
	ReportsService endpoints.	decisions made on incorrect data.		
G07	Scheduled Reports Not Wired The Report database model has isScheduled, schedule (cron), and recipients fields, but no scheduler reads these records or triggers report generation.	Management cannot receive automated daily/weekly claims summaries. Finance cannot receive automated settlement reports. Compliance reports must be generated manually.	Management, Finance, Compliance	Critical

High-Priority Gaps (P2) — Significant Efficiency & Compliance Impact

#	Gap	Business Impact	Priority
G08	No Formal Appeal / Dispute Management Rejected claims can be resubmitted (resubmissionCount field exists), but there is no structured appeal workflow, appeal reason capture, appeal timeline tracking, or final adjudication record.	Providers have no formal channel to contest rejections. Appeals are handled via phone/email, creating an untracked shadow process and potential liability.	High
G09	Real-Time Notifications (WebSocket) Absent All notifications are queue-based emails/SMS. There is no browser push notification or WebSocket event when a claim is assigned, approved, or escalated.	Makers and checkers must manually refresh queues to discover new work. Supervisors miss real-time escalation signals. Average response time increases.	High
G10	No Pre-Authorisation Management High-value claims (>KES 200,000) trigger a fraud warning requiring a pre-auth letter, but no pre-authorisation module exists — no pre-auth requests, no tracking,	Pre-auth letters are manually checked and not linked to the claim in the system. High-value claims can be processed without a verified pre-auth,	High

#	Gap	Business Impact	Priority
	no linkage to the subsequent claim.	increasing fraudulent large-claim risk.	
G11	Provider Performance Scorecard Missing The system collects sufficient data (approval rates, fraud signals, resubmission rates, processing times per provider) but no scorecard view is surfaced. Provider suspension/blacklisting is manual.	CIC cannot proactively identify high-fraud or non-compliant providers. Contracting decisions are made without data-driven provider quality metrics.	High
G12	Duplicate Detection Cross-Provider Duplicate invoice detection only checks within the same provider's claims. A member could be billed by two different providers for the same service episode.	Cross-provider duplicate billing is a significant fraud vector for coordinated rings. Current detection misses this entirely.	High
G13	No Claims Aging / TAT Dashboard Turnaround time data exists in the processing-time report but is not surfaced as an aging dashboard showing claims by days-in-queue, breached SLA, and at-risk items.	Supervisors lack a daily operational view to manage queue backlogs. KPIs for regulator or board reporting cannot be produced without manual extraction.	High
G14	Bulk Actions (Approve / Reject / Assign) Makers and checkers can only action one claim at a time. No bulk selection, bulk assignment, or bulk rejection with shared reason exists.	During high-volume periods (month-end), individual claim processing creates a bottleneck. A supervisor cannot delegate a batch of 50 claims to a maker in one action.	High
G15	Configurable SLA Thresholds in UI The SystemConfig table exists for key-value configuration but no admin UI allows setting SLA thresholds (e.g. maker review = 24h, checker review = 48h, payment = 72h). Values are hardcoded.	SLA changes require a code deployment. Different provider contract tiers with different SLAs cannot be supported without engineering involvement.	High
G16	EDMS / eOxygen Live Integration Untested Both integrations run in graceful-	Documents are not being archived to EDMS. eOxygen does not receive	High

#	Gap	Business Impact	Priority
	degradation mode (no API keys configured). The outbound sync code exists but has not been tested against the actual EDMS and eOxygen endpoints in production.	approved claim data for payment linkage. The core system-of-record is incomplete.	

Enhancement Gaps (P3 & P4) — Future Value

#	Gap	Business Value	Priority
G17	ML-Based Anomaly Scoring The anomalyScore field exists on 0crExtraction but is never populated. Rule-based fraud signals exist; a trained ML model would surface subtler patterns.	Reduce false-positive fraud flags by 30–40%; surface patterns invisible to rules (unusual procedure-diagnosis combinations, provider billing velocity shifts).	Medium
G18	Provider Self-Service Portal (Mobile-Responsive) The provider-facing dashboard exists but is not optimised for mobile. Providers at clinic sites often submit from tablets.	Reduces submission errors; increases provider adoption and on-time submission rates. Supports scan-to-submit from clinical environments.	Medium
G19	Scan Station / Physical Scanner Integration Email ingestion is live. The SRD specifies a scan station mode where a physical barcode scanner triggers claim retrieval and document attachment directly in the UI.	Enables CIC branch scanning workflows without email as intermediary. Faster processing of paper-first claims.	Medium
G20	Adjudication Rules Engine All benefit validation is manual. No rules engine exists to auto-calculate eligible amounts, apply excess/co-pay, or enforce benefit limits per policy.	Would eliminate the majority of manual calculator work by claims officers. Reduces adjudication time from ~15 min to ~3 min per claim.	Medium
G21	Policy / Benefit Plan Management No policy or benefit plan records exist in the system. The adjudication rules engine (G20) depends on this data being available.	Enables in-system eligibility and benefit cap enforcement, reducing dependence on external Smart system lookups.	Medium
G22	Advanced Drill-Down Analytics	Management can identify trends and anomalies	Low

#	Gap	Business Value	Priority
	Dashboard and Reports show summary-level charts. No drill-down (click provider → see their claims), cohort analysis, or period-over-period comparison exists.	without custom SQL exports. Reduces time-to-insight for board reporting from days to minutes.	
G23	Data Retention & GDPR-Style Purge Automation The PurgeRequest model exists with approval workflow, but there is no automated scheduler to purge claims/documents older than the configured retention period.	Compliance with data protection laws and CIC data governance policy. Reduces storage costs over time.	Low
G24	Log Retention Configuration UI Activity logs accumulate indefinitely. Retention period is not configurable from the admin UI — requires direct database query or code change.	Prevents unbounded database growth. Meets audit log retention requirements without engineering involvement.	Low

Gap Summary by Domain

Security (G02, G03): 2FA and password reset are partially built but not functional — quick wins with high impact.

Compliance (G01, G06, G07): Payment tracking, live reporting, and scheduled reports are the most critical gaps for financial governance.

Operations (G05, G13, G14): SLA enforcement, aging dashboard, and bulk actions directly affect daily claims officer productivity.

Risk (G04, G12): Member eligibility and cross-provider duplicate detection are the most significant fraud-control gaps.

SECTION 4

Implementation Plan

Four delivery phases over 24 weeks. Each phase is sequenced so that later phases build on the foundations established earlier. Critical security and data integrity fixes come first.

Phase 1 — Foundations & Security

4 Items

Weeks 1–4 · Estimated 8 developer-weeks

Gaps G02, G03, G06, G16



G02 — Enable Two-Factor Authentication

Rename `two-factor.controller.ts.disabled` → `two-factor.controller.ts` and register it in the `AuthModule`. Wire the existing `TwoFactorService` endpoints (`POST /auth/2fa/generate`, `POST /auth/2fa/enable`, `POST /auth/2fa/verify`) through the router. Update the JWT strategy to check `twoFactorEnabled` and require a second TOTP step before issuing the final token. Make 2FA mandatory for Admin, Supervisor, Checker, and Fraud Officer roles.

Backend: 2 days

Frontend: 1 day

Testing: 1 day

Module: auth



G03 — Password Reset Flow

Add a `passwordResetToken` and `passwordResetExpiry` field to the `User` model (migration). Implement `POST /auth/forgot-password`: generate a secure random token, store its hash, email a reset link (valid 1 hour) via the existing `EmailService`. Implement `POST /auth/reset-password`: validate token, enforce password policy (min 8 chars, complexity), clear the token. Update the `ForgotPassword` and a new `ResetPassword` frontend page to call these endpoints.

Backend: 3 days

Frontend: 2 days

DB migration: 0.5 days

Module: auth



G06 — Wire Reports Page to Live API

The `ReportsService` backend has complete implementations for all report types. Refactor the `Reports` frontend page to call `GET /api/reports/claims-volume, /approvals-rejections, /processing-time, /provider-performance, and /fraud-summary` via API instead of reading the `Zustand` store. Add date-range and filter params. Add loading skeletons and error states. This ensures accuracy for any dataset size.

Frontend: 4 days

Backend: 1 day (minor fixes)

Module: reports



G16 — Commission EDMS & eOxygen Live Integration

Obtain API credentials from the EDMS and eOxygen system owners. Configure EDMS_BASE_URL, EDMS_API_KEY, EOXEGEN_BASE_URL, EOXEGEN_API_KEY in the production environment. Run end-to-end integration tests against staging endpoints. Add a health-check panel in Settings showing last-sync timestamp, sync queue depth, and error count for each integration. Add retry logic with exponential backoff for failed syncs.

DevOps: 2 days

Backend: 2 days

Testing: 2 days

Module: common/integrations

Phase 2 — Risk & Operations

6 Items

Weeks 5–12 · Estimated 14 developer-weeks Gaps G04, G05, G07, G12, G13, G14



G04 — Member Eligibility Verification

Create an EligibilityService that calls the eOxygen/Smart member API at claim submission time. Check: (a) member exists, (b) policy is active on date of service, (c) benefit type is covered. Store eligibility response on the claim (eligibilityStatus, eligibilityCheckedAt, benefitBalance). If eligibility check fails, auto-flag the claim as Incomplete and surface a specific reason in the fraud signals panel. Allow manual override by a Supervisor with audit trail.

Backend: 4 days

Frontend: 2 days

DB migration: 1 day

Module: claims, workflow



G05 — SLA Enforcement & Auto-Escalation

Add a BullMQ scheduled job (sla-checker) that runs every 30 minutes. For each claim in an active workflow stage, compare elapsed time against configurable thresholds from SystemConfig (e.g. maker_review = 24h, checker_review = 48h). On breach: (1) send email/SMS alert to assignee and their supervisor, (2) set slaBreached = true on the claim, (3) escalate to supervisor queue if unactioned after 2x the threshold. Surface SLA status badge (On Track / At Risk / Breached) on all claim list views and the workflow dashboard.

Backend: 4 days

Frontend: 2 days

DB migration: 1 day

Module: workflow, notifications



G07 — Scheduled Report Delivery

Wire a NestJS @Cron scheduler that reads all active Report records with `isScheduled=true`. At each scheduled time: execute the corresponding `ReportsService` method, generate Excel/PDF output using the existing export logic, store the result as a `ReportExecution`, and email to all listed recipients. Add a Reports admin UI to create scheduled reports, set cron expressions, and manage recipient lists. Add a report run history panel showing last 10 executions with status and download link.

Backend: 4 days

Frontend: 3 days

Module: reports, notifications



G12 — Cross-Provider Duplicate Detection

Extend the `computeFraudSignals` function to query across all providers when checking for duplicate invoice numbers and member + date-of-service + diagnosis combinations. Add a `cross_provider_duplicate` fraud signal type. Surface a dedicated Duplicate Claims dashboard under Fraud Queue showing matched pairs with a side-by-side comparison view. Allow a Fraud Officer to mark duplicates as confirmed / cleared with investigation notes.

Backend: 3 days

Frontend: 2 days

Module: claims, fraud



G13 — Claims Aging & TAT Dashboard

Add a dedicated Aging Report page (or tab on the Workflow Dashboard) showing: claims grouped by days-in-current-stage (0-1d, 1-2d, 2-5d, 5d+), breach count by stage and by assigned user, average TAT by provider and claim type, a heat-map of bottlenecks by day-of-week. All data served from a new GET `/api/reports/aging` endpoint in `ReportsService`.

Backend: 2 days

Frontend: 3 days

Module: reports, workflow



G14 — Bulk Actions in Queues

Add checkbox multi-select to the Maker Queue, Checker Queue, and Claims list views. Bulk actions toolbar appears when 1+ claims are selected: Assign to me, Assign to user..., Approve selected, Reject selected (with shared reason dialog), Export selected. Backend: add POST `/workflow/bulk-assign`, POST `/workflow/bulk-approve`, POST `/workflow/bulk-reject` endpoints with per-claim audit trail entries. Enforce role restrictions — makers cannot bulk-approve into checker stage.

Backend: 3 days

Frontend: 3 days

Module: workflow, claims

Phase 3 — Settlement & Provider Experience

5 Items

Gaps G01, G08, G09, G11, G15

Weeks 13–18 · Estimated 10 developer-weeks



G01 — Payment Settlement Module

Build a Finance module with three components:

(1) Payment Advice Generation: When a checker approves a claim, auto-generate a structured payment advice record (PaymentAdvice model) capturing approved amount, payable-to provider bank details, and a payment reference number.

(2) Finance Dashboard: New page for Finance role showing claims approved-but-unpaid, batch payment grouping (aggregate multiple claims per provider per period), and export of payment file (EFT/CSV in bank-compatible format).

(3) Payment Confirmation: Finance marks batches as paid, system updates all included claims to status=paid, sends payment confirmation email to provider with claim-level breakdown.

Backend: 5 days

Frontend: 4 days

DB migration: 1 day

New role: Finance



G08 — Formal Appeal & Dispute Workflow

Add an Appeal model: linked to a rejected claim, capturing appeal reason, supporting documents uploaded by provider, submitted date, and adjudication outcome (upheld / dismissed) with notes. Provider portal: shows rejected claims with an Appeal button (available for 30 days post-rejection). Supervisor queue: receives appeals, can view original claim + appeal documents side-by-side, records decision. Notifications: provider receives appeal acknowledgement (auto), and outcome decision (manual trigger by supervisor).

Backend: 3 days

Frontend: 3 days

DB migration: 0.5 days

Module: claims, workflow



G09 — Real-Time WebSocket Notifications

Add a NestJS WebSocket gateway (@WebSocketGateway with Socket.IO). Emit events on: claim assigned to user, claim approved/rejected, SLA breach, new appeal submitted, batch processing complete. Frontend: subscribe on login using the existing auth token. Show in-app notification bell with unread count, notification drawer with mark-as-read, and toast pop-ups for urgent events (SLA breach, fraud flag). Gracefully falls back to polling if WebSocket unavailable.

Backend: 3 days

Frontend: 2 days

Module: notifications



G11 — Provider Performance Scorecard

Compute a monthly provider scorecard from existing data: approval rate, average processing TAT, fraud signal frequency, resubmission rate, incomplete submission rate. Surface as a Provider Detail page tab visible to Admin and Supervisor. Add a provider ranking table on the Providers list page (sortable by score). Automated monthly scorecard email to provider admin. Threshold-based automatic suspension recommendation (e.g. fraud rate >15% → flag for review).

Backend: 3 days

Frontend: 2 days

Module: providers, reports



G15 — System Configuration Admin UI

Build a System Config admin page (admin-only) that reads/writes the SystemConfig table. Configurable settings: SLA thresholds per workflow stage (hours), high-value claim threshold (KES), fraud signal sensitivity toggles, maximum daily submissions per provider, log retention period (days), email footer and sender name. Changes take effect immediately (the SLA checker job reads config on each run). Full audit trail of who changed what configuration and when.

Backend: 2 days

Frontend: 2 days

Module: admin, workflow

Phase 4 — Intelligence & Scale

7 Items

Weeks 19–24 · Estimated 6 developer-weeks

Gaps G10, G17–G24



G10 — Pre-Authorisation Management

A PreAuthorisation model linked to a provider and member. Provider submits a pre-auth request from their portal before the service is rendered. CIC approves/declines with conditions and amount limits. Approved pre-auth generates a unique reference number. When a claim is submitted for >KES 200,000, the system requires a linked pre-auth reference; claims without one are auto-flagged and held pending pre-auth verification.

Backend: 3 days

Frontend: 2 days

DB migration: 1 day



G17 — ML-Based Anomaly Scoring

Train an anomaly detection model on historical approved/rejected/fraud claims. Features: invoice amount, provider type, diagnosis-procedure pair frequency, member claim velocity, day-of-week, batch size. Score each incoming claim 0–1 on anomaly. Populate the existing anomalyScore field on OcrExtraction. Surface as a "Risk Score" indicator on the claim detail page with contributing factor breakdown.

Data Science: 5 days

Backend: 2 days

Frontend: 1 day



G18 — Mobile-Responsive Provider Portal

Audit all provider-facing pages (Provider Dashboard, Batch Upload, Claims list, Appeal, Profile) for mobile breakpoints. Fix layout issues on screens <768px. Add a Progressive Web App (PWA) manifest so providers can install the portal as a home-screen app on Android/iOS tablets. Add camera-capture file upload option for mobile document submission.

Frontend: 4 days

PWA config: 1 day



G20 & G21 — Adjudication Rules Engine & Policy Management

Import or create a PolicyPlan model with benefit tables (inpatient limit, outpatient limit, dental limit, optical limit, co-pay %, excess amounts). Sync from Smart/eOxegen if available, or allow manual management. Build a rules engine (AdjudicationService) that, given a member's policy and a claim, computes: eligible amount, excess deducted, co-pay deducted, and net payable. Surface the adjudication breakdown on the claim detail page for maker review, pre-populated so the officer just confirms or overrides.

Backend: 5 days

Frontend: 3 days

DB migration: 1 day



G22 — Advanced Drill-Down Analytics

Add drill-down navigation: click a bar in the Provider Performance chart → open that provider's claims. Click a status segment → filtered claims list. Add period-over-period comparison toggle (e.g. this month vs last month). Add cohort analysis: track a batch of claims submitted in a week and show their lifecycle progression over time. All powered by the existing ReportsService with additional filter parameters.

Frontend: 4 days

Backend: 1 day



G23 & G24 — Data Retention & Log Management

Add a @Cron nightly job that reads SystemConfig for retention periods and: (1) auto-creates PurgeRequest records for claims/documents past their retention date (pending human approval), (2) deletes ActivityLog records older than the configured retention period (default 2 years). Admin UI: log retention configuration field in System Config page (G15). Purge request list with one-click approve/decline.

Backend: 2 days

Frontend: 1 day

SECTION 5

Delivery Timeline

A 24-week horizon from 12 May 2026 across four sequential phases. Each phase gate includes a stakeholder review before the next phase begins.

Phase	Weeks	Dates	Deliverables	Effort	Gate Criteria
Phase 1 Foundations	1–4	12 May – 9 Jun 2026	2FA enabled · Password reset · Live reports API · EDMS/ eOxygen commissioned	8 dev-weeks	All privileged users can enrol 2FA; reports match DB counts; EDMS sync log shows 0 errors
Phase 2 Risk & Ops	5–12	9 Jun – 4 Aug 2026	Member eligibility check · SLA enforcement · Scheduled reports · Cross-provider duplicates · Aging dashboard · Bulk actions	14 dev-weeks	Zero claims proceed without eligibility result; SLA breach notifications firing in staging; bulk approve tested at 100-claim scale
Phase 3 Settlement & UX	13–18	4 Aug – 15 Sep 2026	Payment settlement module · Appeal workflow · WebSocket notifications · Provider scorecard · System config UI	10 dev-weeks	Finance can export payment file; providers can submit appeals; in-app notifications appear <2s after event
Phase 4 Intelligence	19–24	15 Sep – 27	Pre-auth management · ML anomaly	6 dev-weeks	ML model AUC >0.80 on test set;

Phase	Weeks	Dates	Deliverables	Effort	Gate Criteria
		Oct 2026	scoring · Mobile PWA · Adjudication engine · Drill-down analytics · Data retention		pre-auth flow tested with 5 providers; PWA installs on Android/iOS

Parallel Quick Wins (can start immediately, <1 week each)

The following items require minimal engineering effort and can be started in parallel with Phase 1 planning:

- **Enable 2FA controller** (rename file, register module) — 1 day
- **Fix password reset endpoints** (add 2 routes to auth controller) — 2 days
- **Wire reports to API** (replace store reads with fetch calls) — 1–2 days per report tab

These three items alone close 3 of the 7 critical gaps.

Resource Allocation

Role	Phase 1	Phase 2	Phase 3	Phase 4	Notes
Backend Engineer	1×	2×	1×	1×	NestJS, Prisma, BullMQ
Frontend Engineer	1×	1×	1×	1×	React, Zustand, Recharts
Data Scientist	—	—	—	1×	Phase 4 only — anomaly model (G17)
DevOps / QA	0.5×	0.5×	0.5×	0.5×	CI pipeline, integration testing, staging
BA / Team Lead	0.5×	0.5×	0.5×	0.5×	Stakeholder review, acceptance criteria

SECTION 6

Success Metrics & KPIs

Quantifiable targets for each phase gate and the 12-month post-launch horizon. Baselines reflect current observed performance; targets are conservative but meaningful.

CLAIM PROCESSING TAT (MAKER → PAYMENT)

Current: Unmeasured (manual)

Target (Phase 2): <48 hours end-to-end

SLA COMPLIANCE RATE

Current: Unknown (not tracked)

Target (Phase 2): >90% claims within SLA

FRAUD DETECTION RATE

Current: Rule-based, 10 signal types

Target (Phase 4): +30% with ML scoring (AUC >0.80)

FALSE POSITIVE FRAUD FLAGS

Current: ~25% estimated (round-amount rule overfire)

Target (Phase 4): <10% false positive rate

GHOST CLAIM RATE

Current: Unknown (no eligibility check)

Target (Phase 2): 0% ineligible claims reach approval

PROVIDER ONBOARDING TIME

Current: 5–10 business days (manual)

Target (Phase 3): <3 business days with digital workflow

PAYMENT SETTLEMENT CYCLE

Current: Unknown (no tracking)

Target (Phase 3): <72 hours post-final-approval

REPORT DATA ACCURACY

Current: Client-side only — may miss records

Target (Phase 1): 100% (server-side API driven)

SYSTEM AVAILABILITY

Current: ~97% (no formal SLO)

PROVIDER PORTAL ADOPTION

Current: Email + portal mix

Target: 99.5% uptime (with Redis queue durability)

Target (Phase 4): >80% claims via portal (not email)

Risk Register

Risk	Likelihood	Impact	Mitigation
eOxegen API unavailable or undocumented	Medium	High	Graceful degradation already coded. Request API spec and sandbox from system owner in Phase 1 Week 1. Build mock server for testing.
Member eligibility API response latency >2s	Medium	Medium	Run eligibility check asynchronously after submission. Flag claim as "Eligibility Pending" and update once result arrives (webhook or polling).
ML model training data insufficient (<10,000 labelled claims)	Medium	Low	Phase 4 is last; by then 6+ months of data will exist. Start with simple logistic regression as v1; iterate with more complex model.
Finance team resistance to new payment module	Low	High	Involve Finance lead in Phase 3 design sprint. Ensure EFT file format matches their bank's requirements before build starts.
Provider 2FA adoption friction	Medium	Low	Make 2FA optional for Provider roles; mandatory only for CIC internal privileged accounts. Provide step-by-step onboarding guide.
Scope creep delaying Phase 2	High	Medium	Lock Phase 2 scope at gate review. Any new requests enter a backlog for Phase 3/4 assessment. BA maintains change log.

SECTION 7

Recommendations & Next Steps

Immediate actions, strategic recommendations, and the decision points required before Phase 1 development can commence.

Immediate Actions (This Week)

- ✓ Rename `two-factor.controller.ts.disabled` to `two-factor.controller.ts` and register in `AuthModule` to unblock 2FA — 1 hour effort.
- ✓ Implement `POST /auth/forgot-password` and `POST /auth/reset-password` endpoints in `auth.service.ts` — 2 days.
- ✓ Refactor the Reports page to call the live `/api/reports/*` endpoints instead of the Zustand store — 3 days.
- ✓ Obtain EDMS API credentials and eOxegen sandbox access from system owners; configure in staging environment.
- ✓ Conduct a 1-hour workshop with the Finance team to document their EFT file format requirements for the payment settlement module design.
- ✓ Define SLA thresholds per workflow stage in writing (sign-off from Operations Manager) before Phase 2 development begins.

Strategic Recommendations

Recommendation 1: Treat the Reports fix as an emergency hotfix

The current state — where all report numbers are derived from the browser's in-memory store — means that every management report generated today is potentially incorrect. This should be classified as a data integrity bug and fixed outside of the phased plan, ideally within the current sprint.

Recommendation 2: Don't delay 2FA or password reset

These two items are essentially done — the code exists. The 2FA fix is a file rename and module registration (1 hour). Password reset requires 2 days of

backend work. Both should ship in the next deployment. Every week without them is a security exposure for privileged accounts.

Recommendation 3: Prioritise Phase 2 member eligibility above all other Phase 2 items

Ghost claims (claims for non-members or lapsed policies) represent the highest direct financial risk. Even a lightweight eligibility check — calling eOxygen to confirm the member number exists and the policy is active — provides a significant first-line control. This single feature could prevent material fraudulent payouts.

Recommendation 4: Involve Finance and Compliance in Phase 3 design

The payment settlement module (G01) and data retention (G23/G24) have regulatory implications. Finance must sign off on the EFT file format before a line of code is written. Compliance/Legal should confirm the retention periods align with the Data Protection Act (Kenya) and CIC's own data governance policy.

Decision Points Required from Management

Decision	Owner	Required By	Blocks
Confirm SLA thresholds per workflow stage (hours)	Operations Manager	Phase 2 start	G05, G13, G15
Provide eOxygen/Smart member eligibility API specification	IT / eOxygen Owner	Phase 2 Week 1	G04
Approve EFT file format and bank details management policy	Finance Director	Phase 3 start	G01
Confirm data retention periods (claims, documents, logs)	Legal / Compliance	Phase 3 start	G23, G24
Approve ML model training on historical claims data (GDPR / DPA consent)	Legal / DPO	Phase 4 start	G17
	CISO / IT Director	Phase 1 Week 1	G02

Decision	Owner	Required By	Blocks
Confirm provider 2FA mandate scope (all providers or CIC internal only)			

Conclusion

ClaimsFlow has a strong foundation — the core claim lifecycle, OCR pipeline, fraud detection, and maker-checker workflow are operational. The system is not 40% complete as initially assessed; active usage and the maturity of the implemented modules place it closer to **68% complete**.

However, the gaps that remain are disproportionately important. The absence of a payment module means the claims loop never closes in the system. The absence of member eligibility verification means a critical fraud gate is open. The reports data accuracy issue means management decisions are being made on potentially wrong numbers.

The good news: **three of the seven critical gaps can be closed within two weeks** with minimal engineering effort. Phase 1 is largely activation work — turning on things already built. The real investment is in Phase 2, which delivers the most operational value for the claims processing team.

With the right resources and decision-maker engagement on the open questions above, ClaimsFlow can reach full SRD compliance by **27 October 2026** — a complete, end-to-end automated medical claims platform for CIC Insurance Group.